

VULNERABILITY ASSESSMENT CON NMAP E NESSUS

Obiettivo: Eseguire scansioni di rete, identificare vulnerabilità e valutare i rischi utilizzando strumenti standard di settore come Nmap e Nessus.

Attività:

- Eseguire scansioni di rete con Nmap per identificare host attivi, porte aperte e servizi in esecuzione su metasploitable.

Sfide extra:

- Avviare scansioni di vulnerabilità automatizzate tramite Nessus sempre su metasploitable ed analizzare i risultati.

In questo compito è stata progettata una rete, con due macchine dove in mezzo abbiamo un firewall.

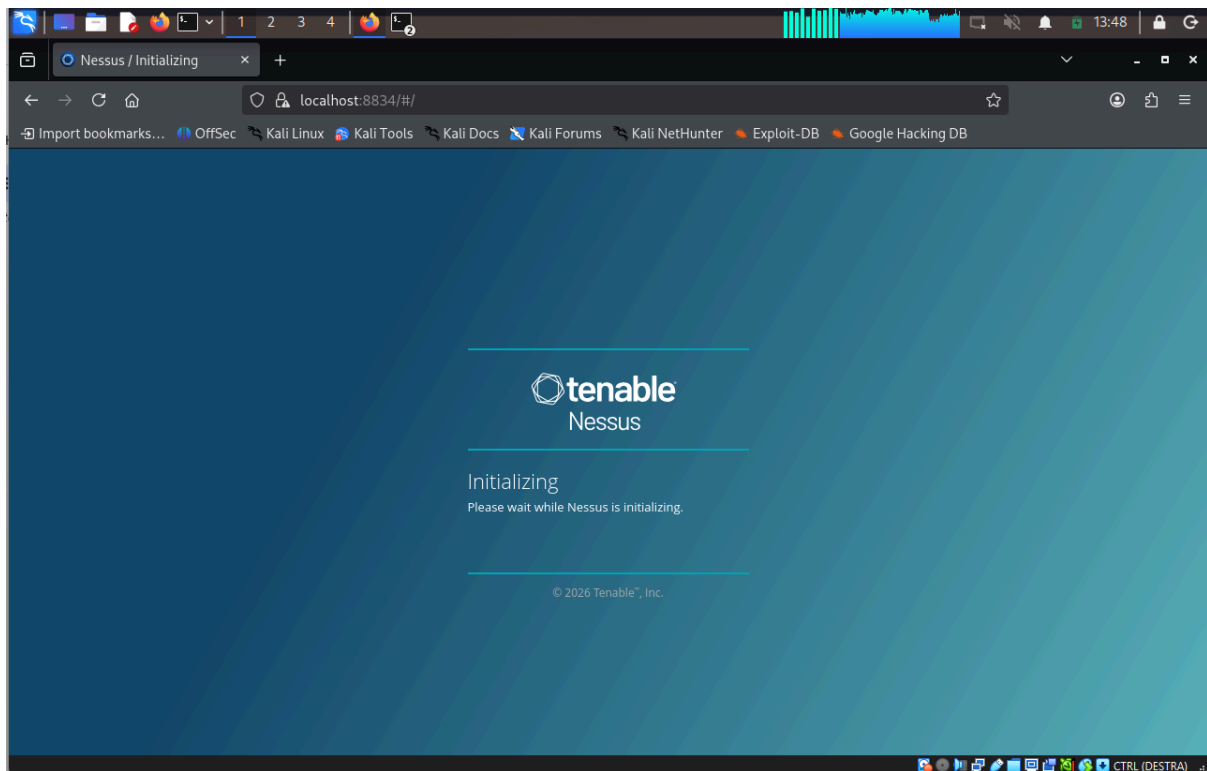
Il firewall (PfSense) ha tre schede di rete, una verso la macchina vulnerabile (Metasploitable) 192.168.50.2/24, una verso la macchina attaccante (Kali Linux) 192.168.100.2/24, e infine l'ultima verso l'esterno 10.0.3.15/24.

Se Kali ha un IP su una sottorete diversa e non c'è un router/firewall a instradare il traffico verso le reti appartenenti alle due macchine, la scansione fallirà a livello di routing.

È stata eseguita una scansione di rete con Nmap per identificare gli host attivi, le porte aperte e i relativi servizi in esecuzione sull'IP di target 192.168.50.2. La scansione ha confermato l'host attivo evidenziando una vasta superficie d'attacco:

```
(kali@kali)-[~]
$ nmap -Pn 192.168.50.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-13 13:35 -0400
Nmap scan report for 192.168.50.2
Host is up (0.020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 0.98 seconds
```



Verificare che la porta 8834 è in ascolto

`sudo ss -tulpn | grep 8834`

Avviare il servizio Nessus:

`sudo systemctl start nessusd`

Per verificare che sia effettivamente attivo:

`sudo systemctl status nessusd`

Andare sul browser, e digitare, <https://localhost:8834>

La fase di ricognizione ha rilevato una superficie d'attacco estremamente elevata dovuta a protocolli obsoleti in chiaro (es. Telnet, r-services) ed a servizi di database esposti.